



EXCELLIUM

Security by Design for PSD2 APIs using OWASP Abuse Case methodology

Yannick Antoine, CISO LUXHUB
Application Security Team, Excellium

NOT in the agenda

Cloud

Cyber X

Blockchain

IoT

Machine Learning

Anomaly Detection

AI

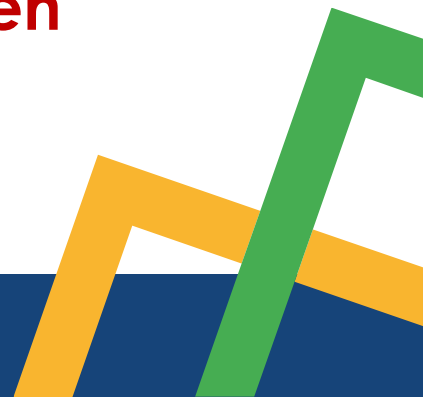
Next generation

APT

Big data

Data-driven

Threat intelligence



IN the agenda

Security by Design

Secure SDLC

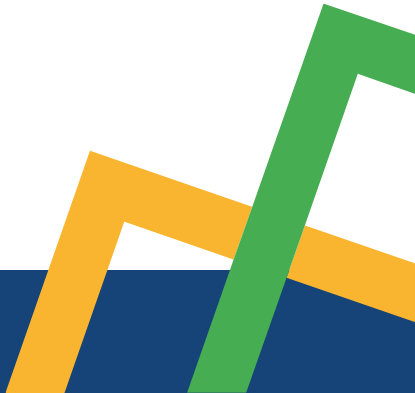
OWASP

Agile

Abuse Cases

APIs

Marketplace



What and why PSD2 ?

PSD2 = Revised Payment Service Directive

PSD

(Payment Service Directive)

The PSD was adopted in 2007.

It created a single market for payments in the EU.

It provided the legal foundation for a Single Euro Payments Area (SEPA).

New Players

Since PSD, the digitalisation of the European economy has progressed.

New services and new players have appeared.

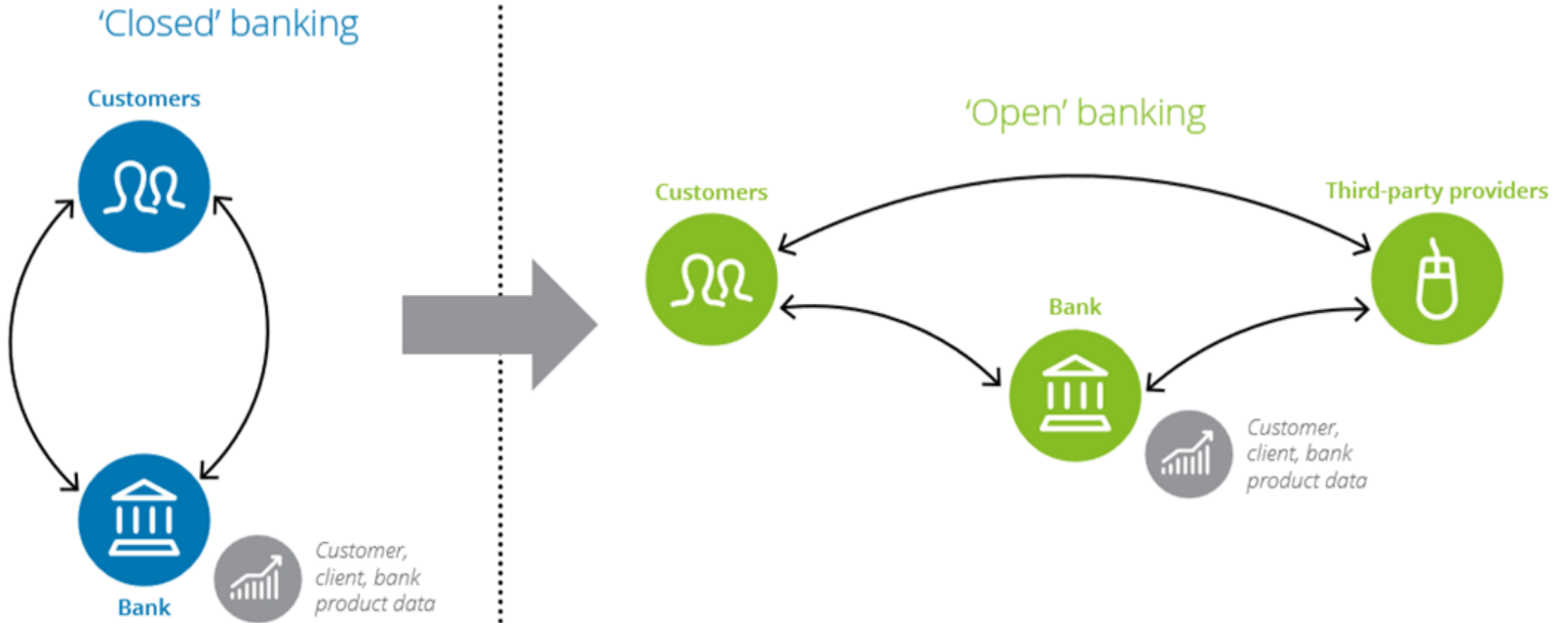
Problem: they were outside the scope of PSD, and therefore not regulated.

PSD2

The objectives of PSD2 are to

- make payments safer
- increase customer's protection
- foster innovation and competition
- ensuring a level playing field for all players, including new ones

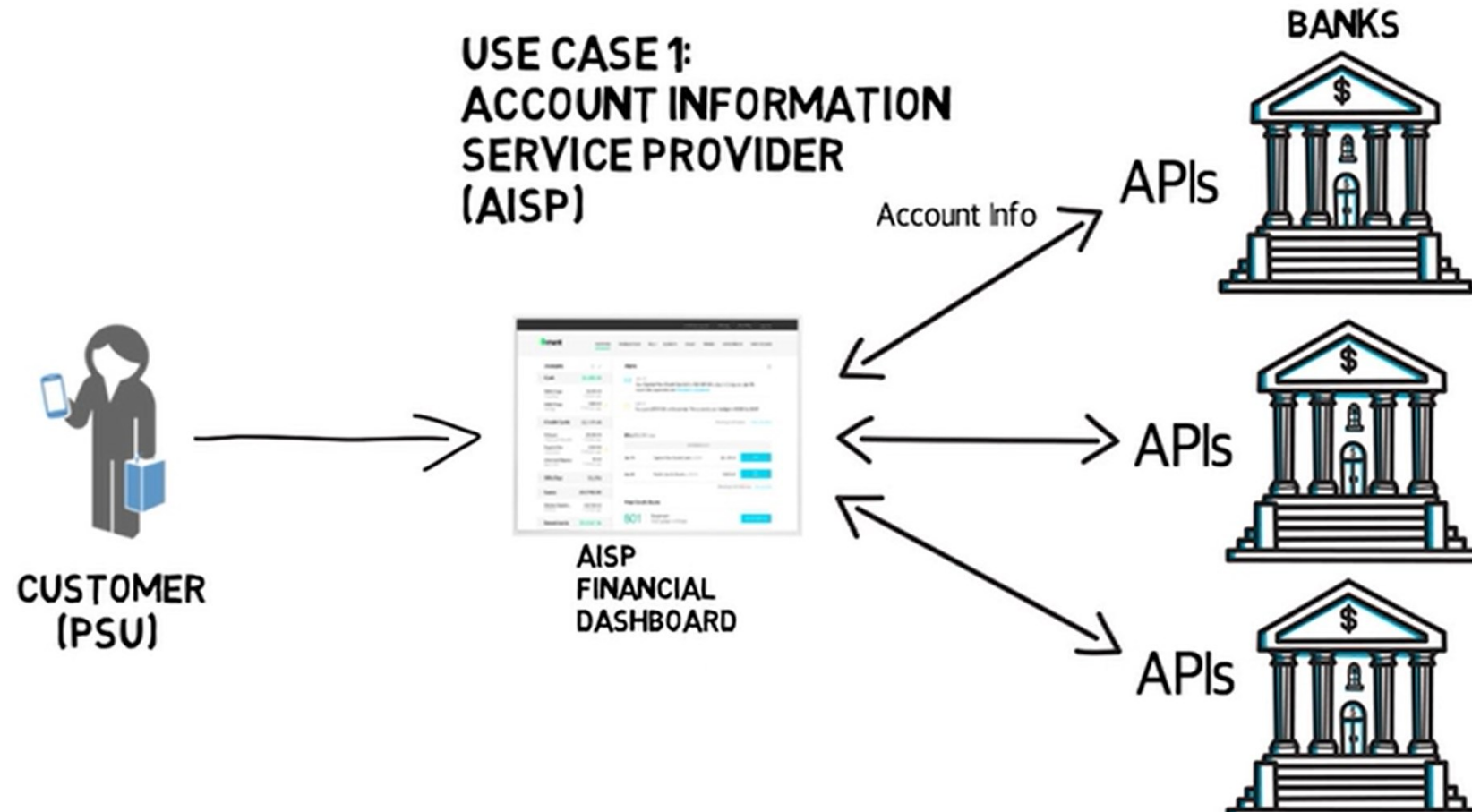
From a Closed to an Open Banking model



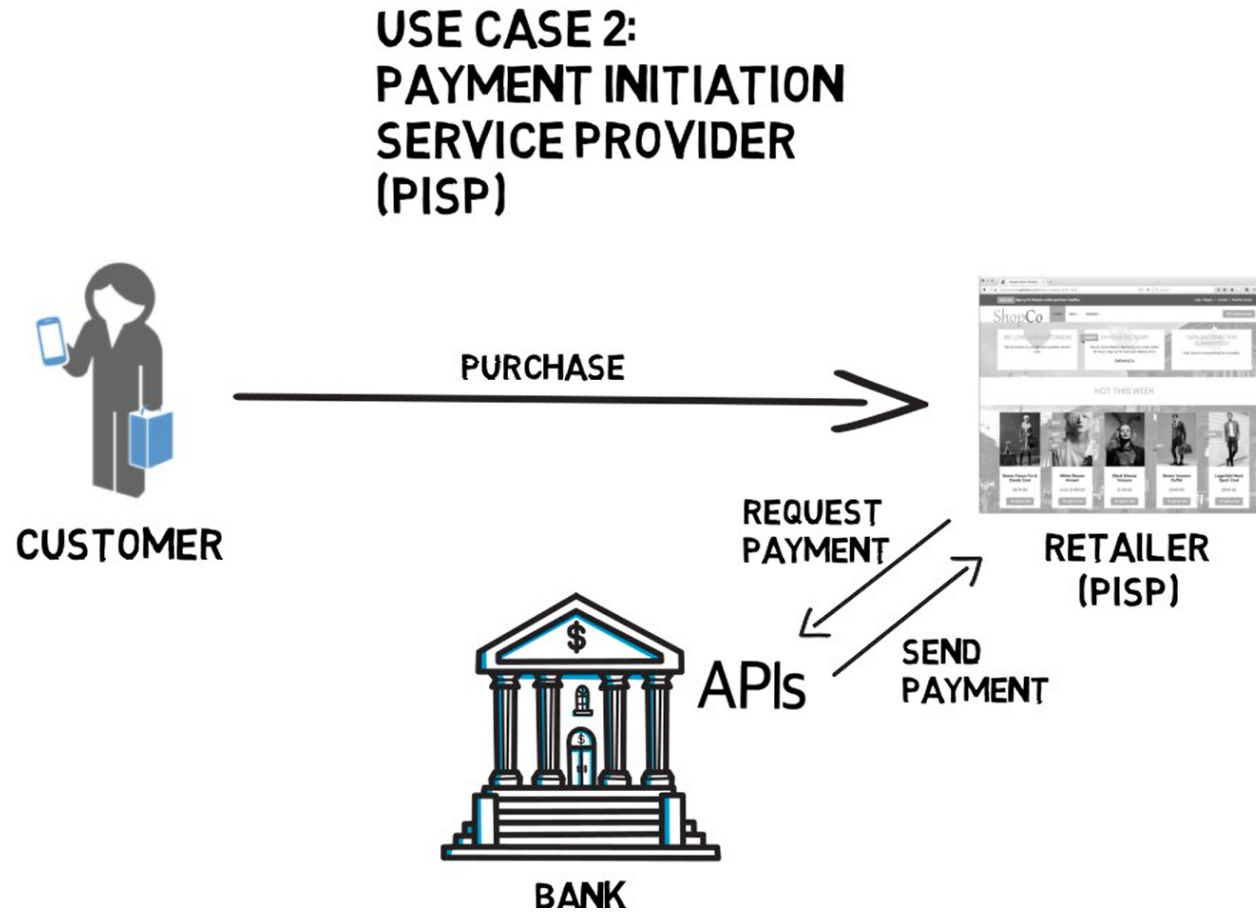
Using public API's



Use Case 1 : AISP



Use Case 2 : PISP



From Regulation to Implementation



PSD2 = EU Regulation

RTS = Regulatory Technical Standards = guidelines on how to implement PSD2

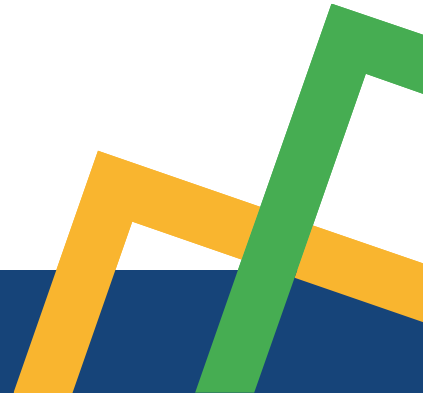
High-Level requirements - No technical details



Two main working groups in EU



Low-Level requirements
Technical details

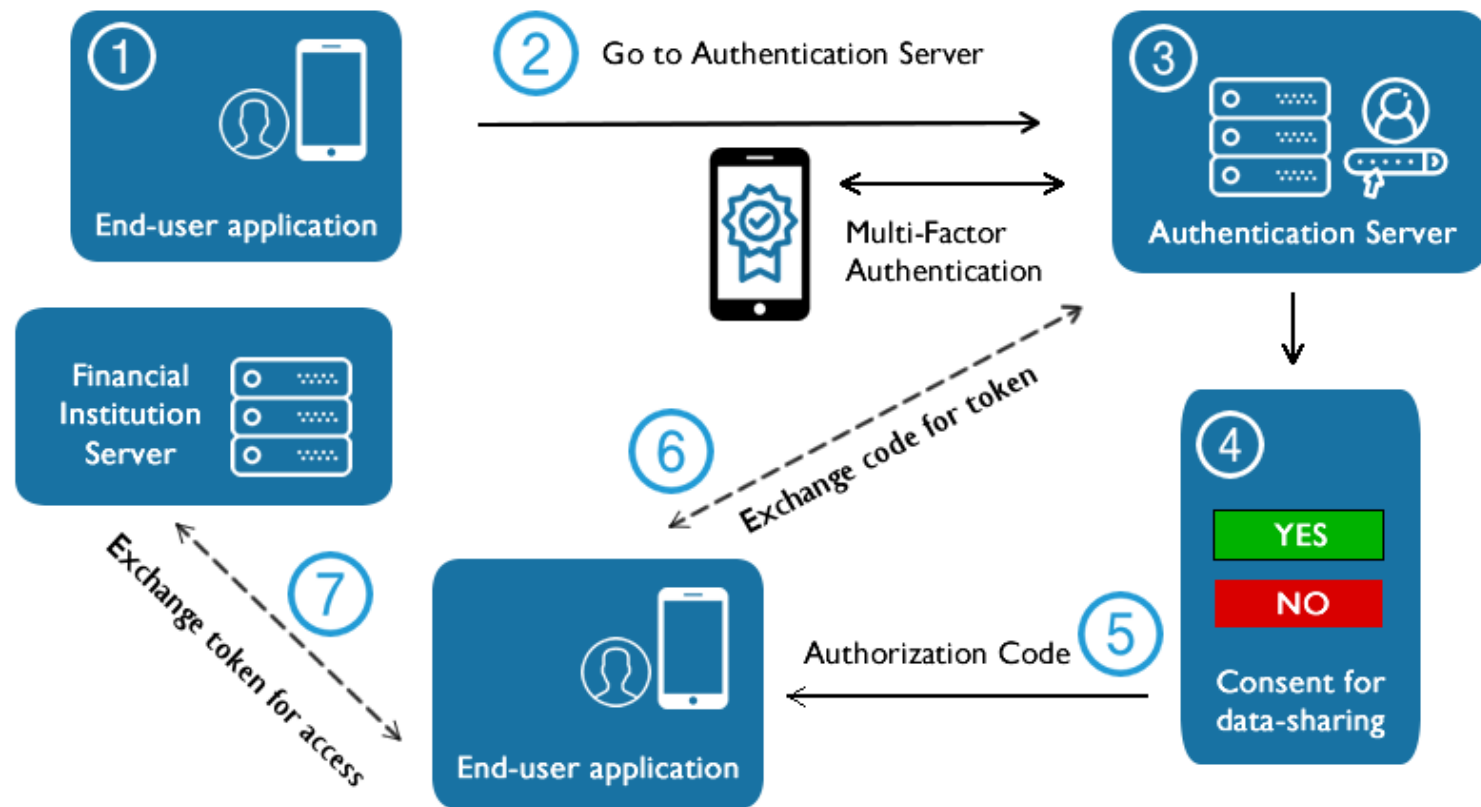


Regulatory Technical Standards: SCA

Strong Customer Authentication

2-factor authentication

OAuth 2.0
+
OpenID Connect



Regulatory Technical Standards: CSC

Common & Secure Communication



**eIDAS
Certificates**

For identification, i.e. understanding whether a party is actually the party they claim to be.

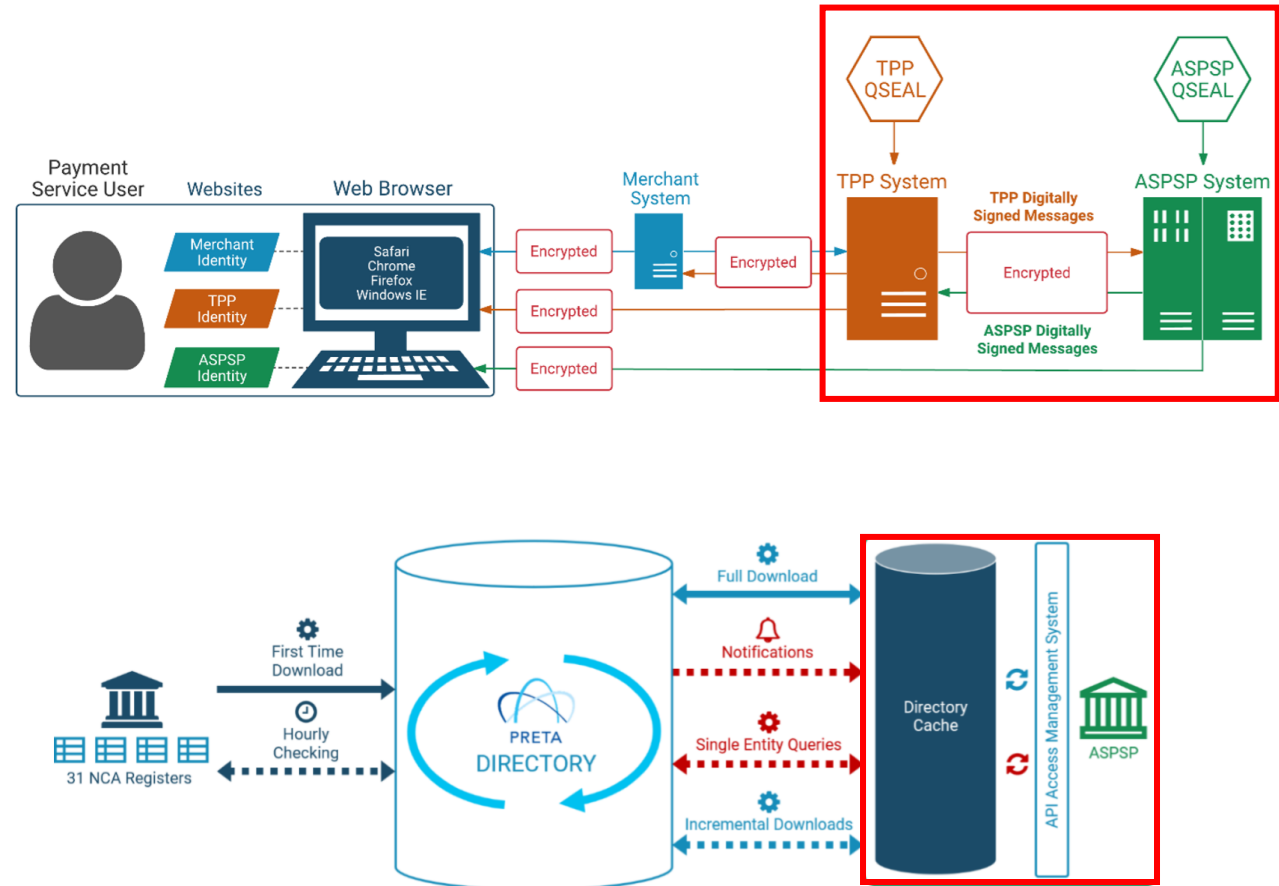
**QWAC
(MA-TLS)
QsealC**

(message signature)



**National Competent
Authority Registers**

For authorisation, i.e. understanding whether a party is regulated and what they are authorised to do.

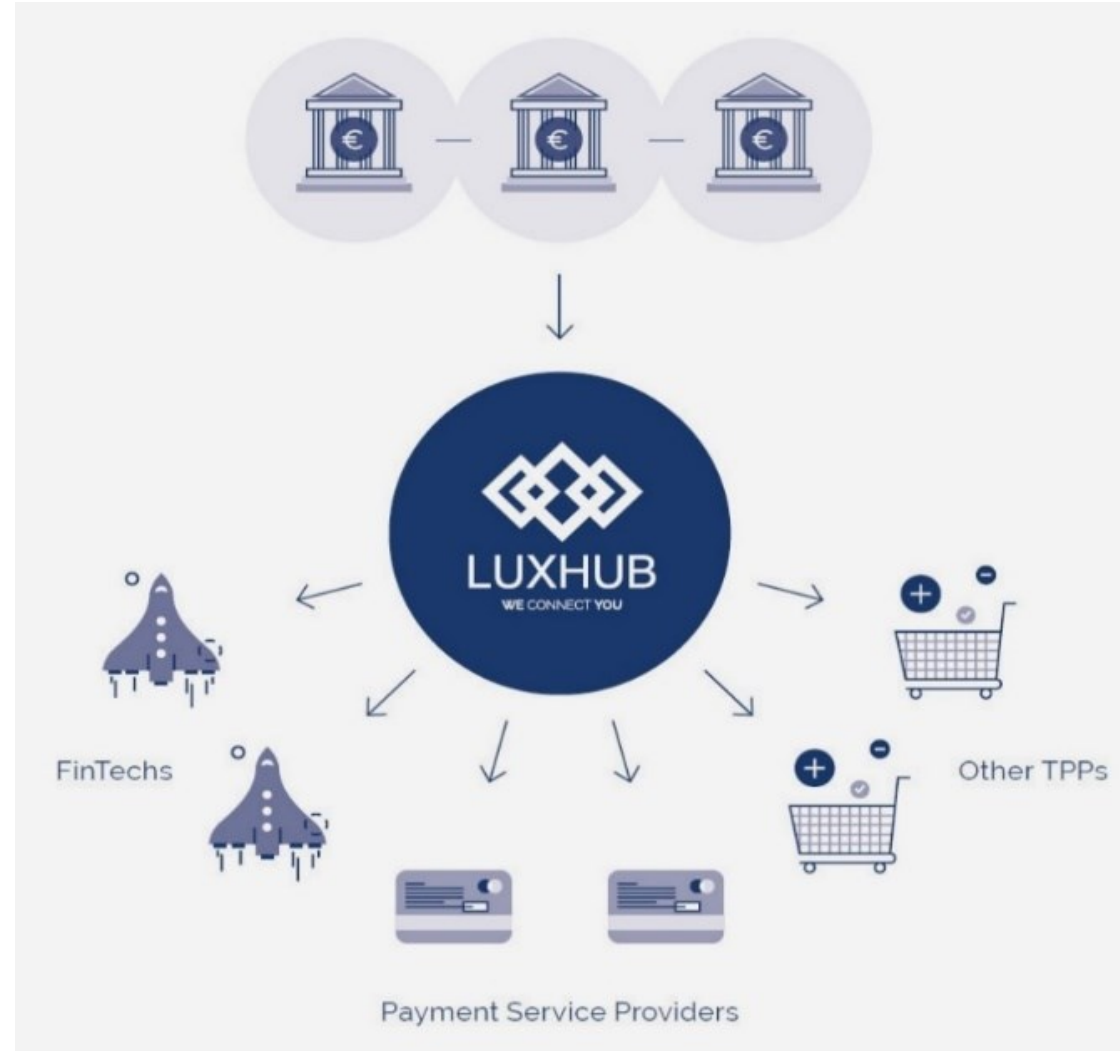




Technical Interconnection
between Banks and other
actors



> 1.1 million
Bank Accounts



31
PSD2 XS2A customers
(Banks)... and counting !



EU
Market

Top Risks

Concentration Risk

LUXHUB = PSD2/API Marketplace interface for
> 80% of Luxembourg Payment Accounts

Cybersecurity Risk

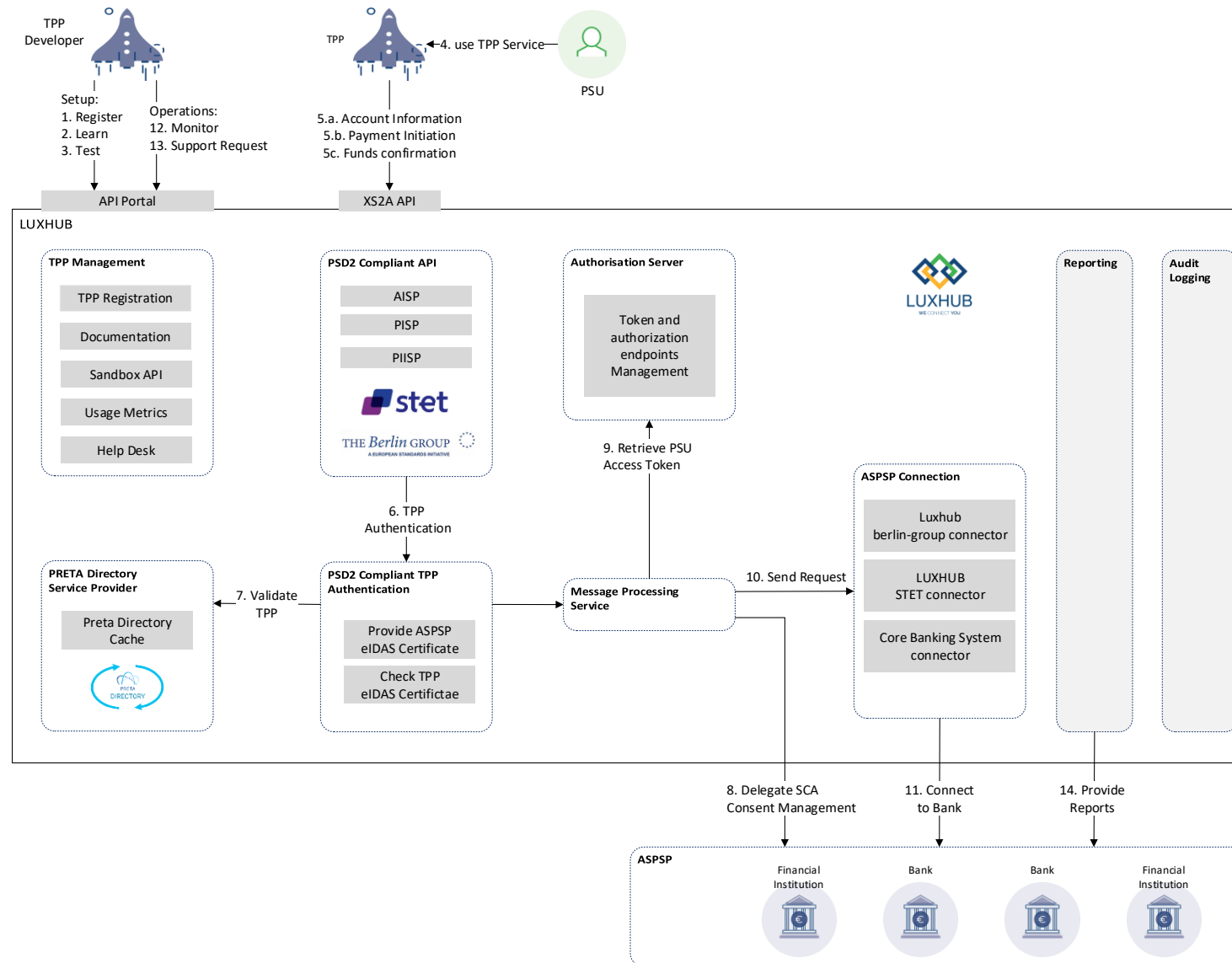
Payment accounts + “Open” system +
internet-facing + new technologies...
=> Cyberattack, Fraud, Denial of Service

Regulatory Risk

PSD2 is “new”:
Regulation has to be interpreted/clarified
Standards are still evolving



Functional Platform



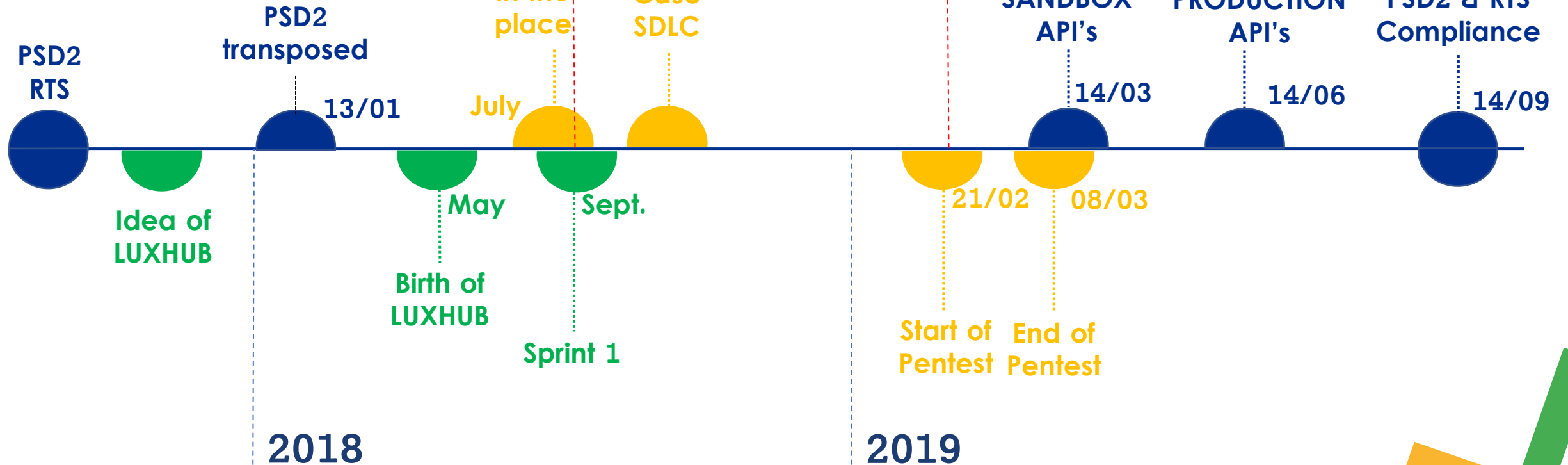
Timeline

< 6 months

Regulatory Timeline

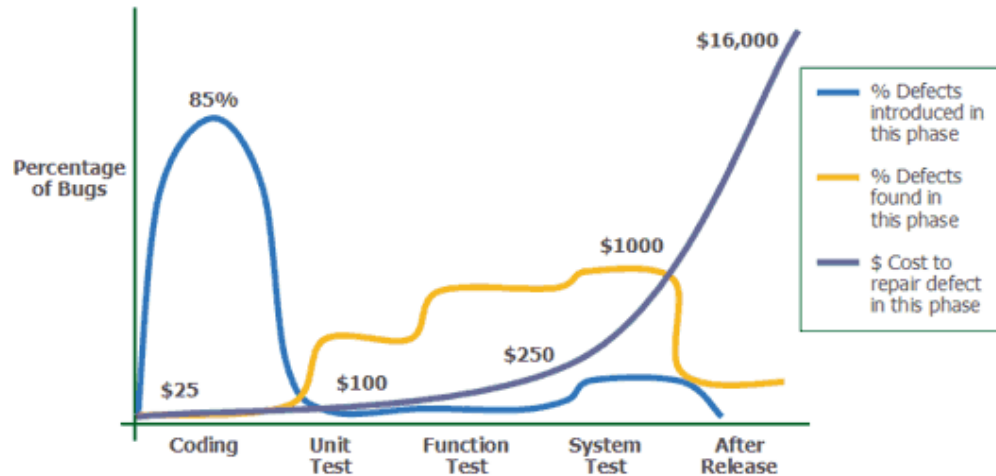
LUXHUB Timeline

Security Timeline



Secure SDLC

The Problem




Find security issues earlier

1. Write a Policy

⇒ ISO27001 A.14 System Acquisition, development, & maintenance policy

2. Develop a Process

⇒ Secure Development & Release Process

3. Onboard Architects/Developers/Testers

⇒ Consultation on design choices

⇒ Formal security review

⇒ Informal discussions

⇒ Awareness Training

4. Integrate Security testing into SDLC

SWOT Analysis

STRENGTHS

- Security requirements in RTS
- Experienced Team
- Management support
- Agile mindset

WEAKNESSES

- New company (no ISMS)
- Moving target (regulation / standard / dev priorities)
- Small Team

OPPORTUNITIES

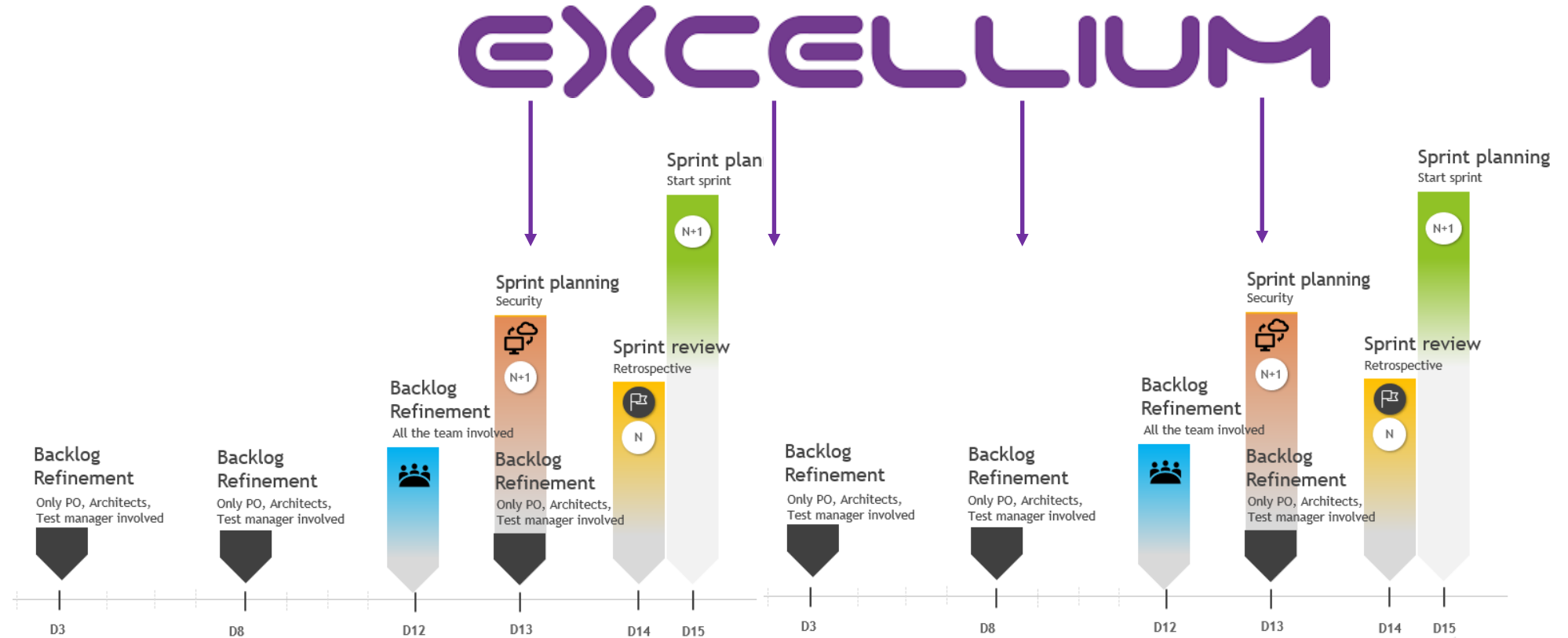
- Build “Security by Design”
- Agile PM Methodology under construction
- Automation (CI/CD/Testing)

THREATS

- Lack of documentation
- Nobody has time to read the policy 😊

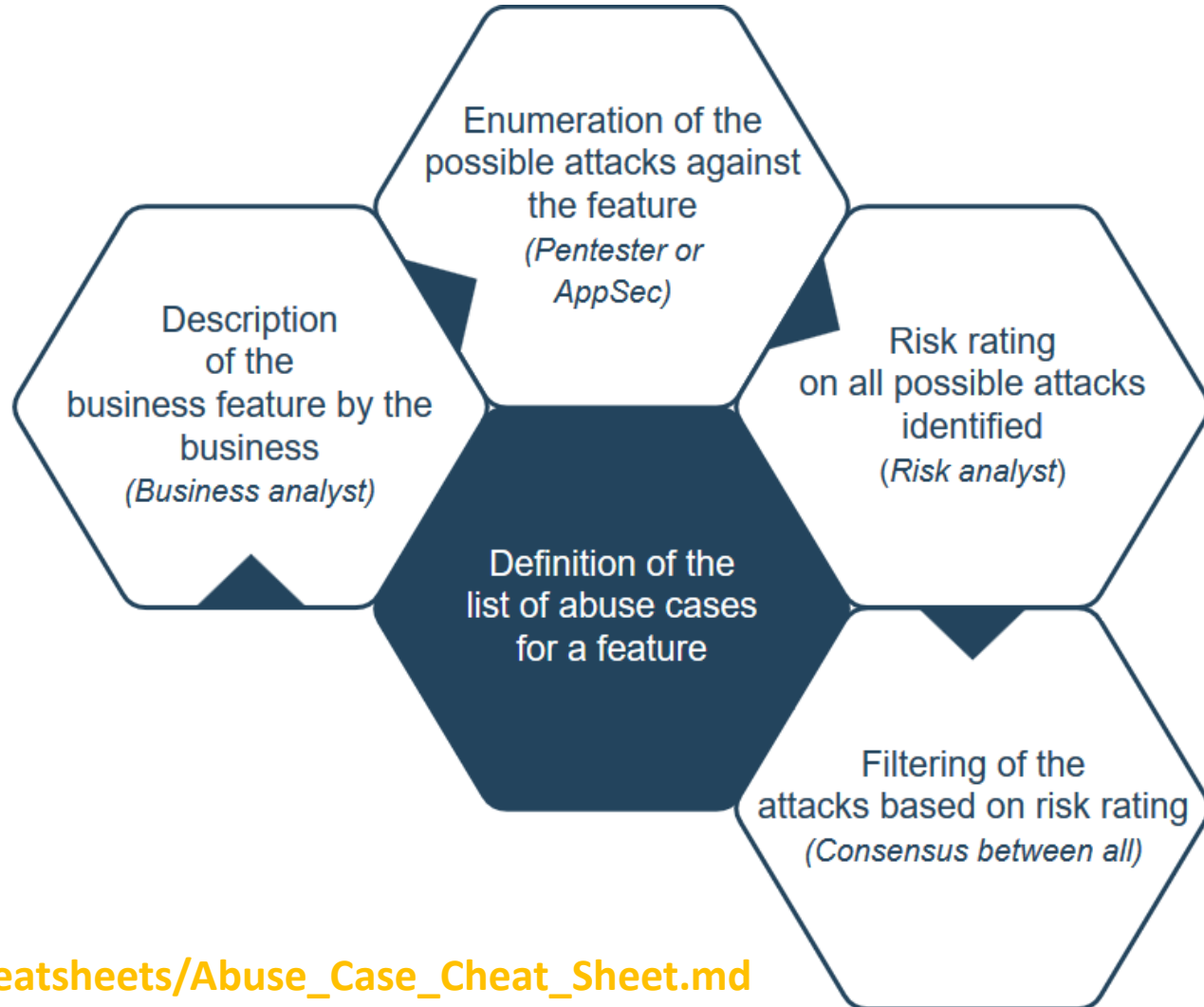


Integrate Security into Sprint Timeline



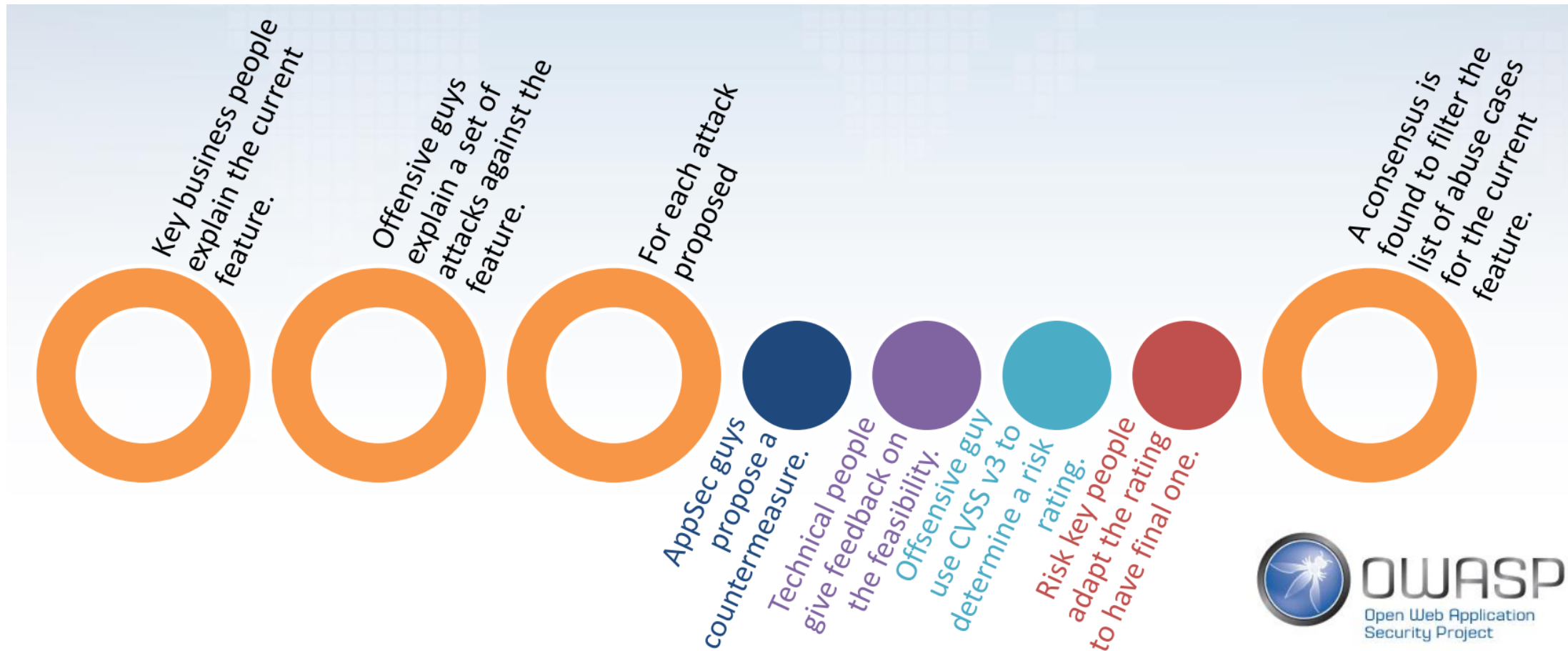
Excellium: Methodology & approach

- Methodology created by Excellium based on Abuse Case concept.
- Applied on several agile projects on different customers since January 2018.
- Presented at the OWASP Atlanta Chapter, Lorraine Java User Group (LorraineJUG) and Luxembourg Java User Group (YAJUG).
- Given to the OWASP foundation in September 2018 under Creative Commons V3 license.
- Applied on LUXHUB project.



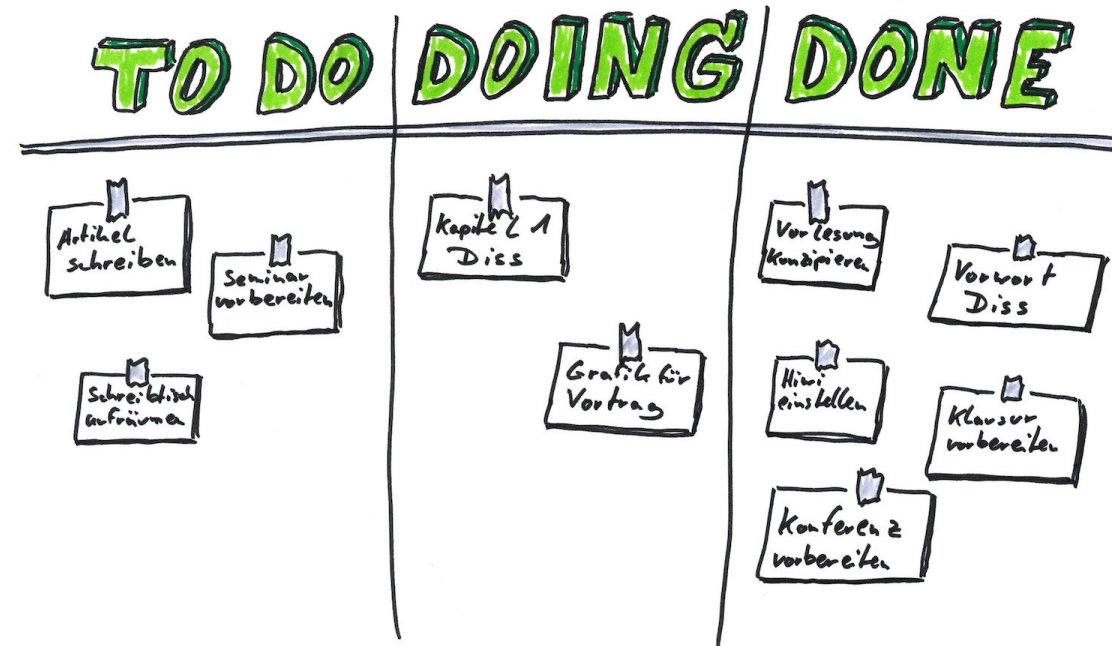
Excellium: Methodology & approach

- Flow of a workshop to identify the list of abuse cases for a feature:



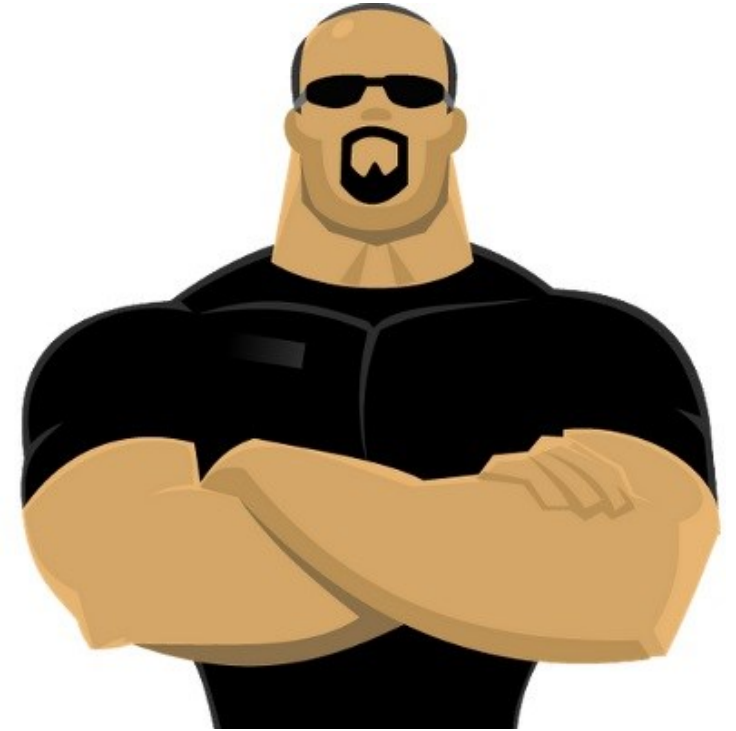
Excellium: Role → Security buddy

- Intervention of the application security team during each Sprint (from 1 to 2 days a week).
- Identification of the abuses cases for every business features plan to be developed.
- Support to developers/architects to identify/create countermeasures against identified abuse cases.
- Support to test team in order to specify how to test the efficiency of the countermeasures against abuses cases and, when applicable, how to automate the tests.
- Train LUXHUB to the methodology.

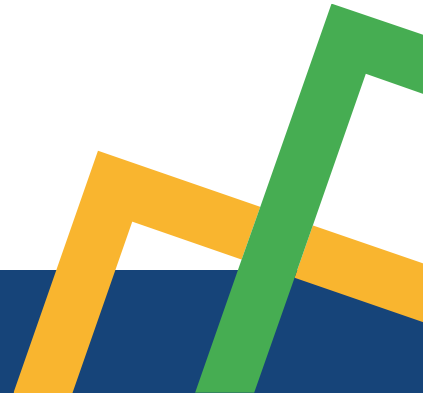


Excellium: Role → Security buddy

- Pre-security assessment of sensitive features to identify issues during the development.
- Review of the external security assessment result in order to provide feedback to LUXHUB about the issues found and derivate countermeasures.
- Challenge the issues found by the external security provider about authenticity, proof, exploitability and rating.



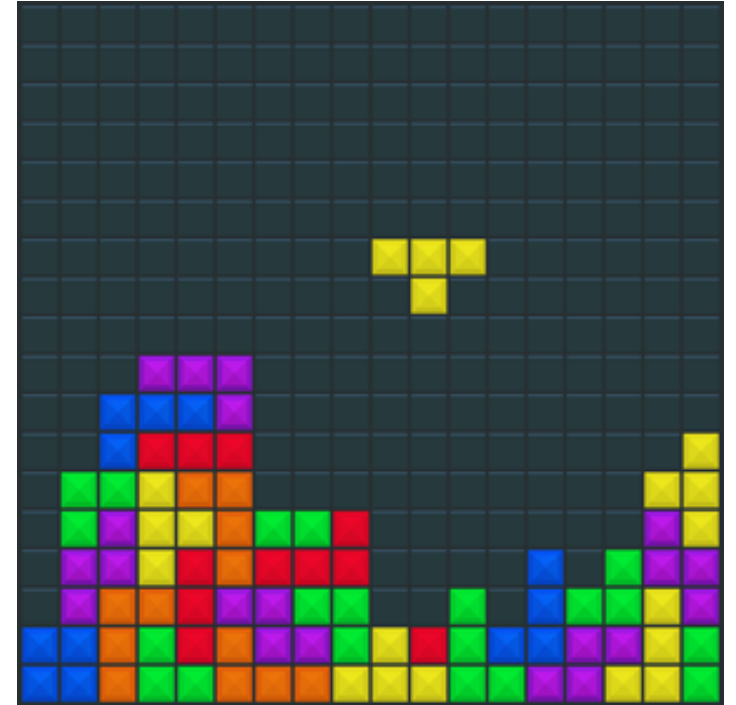
Guide LUXHUB to grow in order to allow them to be Excellium-independent after the production release...



Excellium: Challenges

- **Planning:**

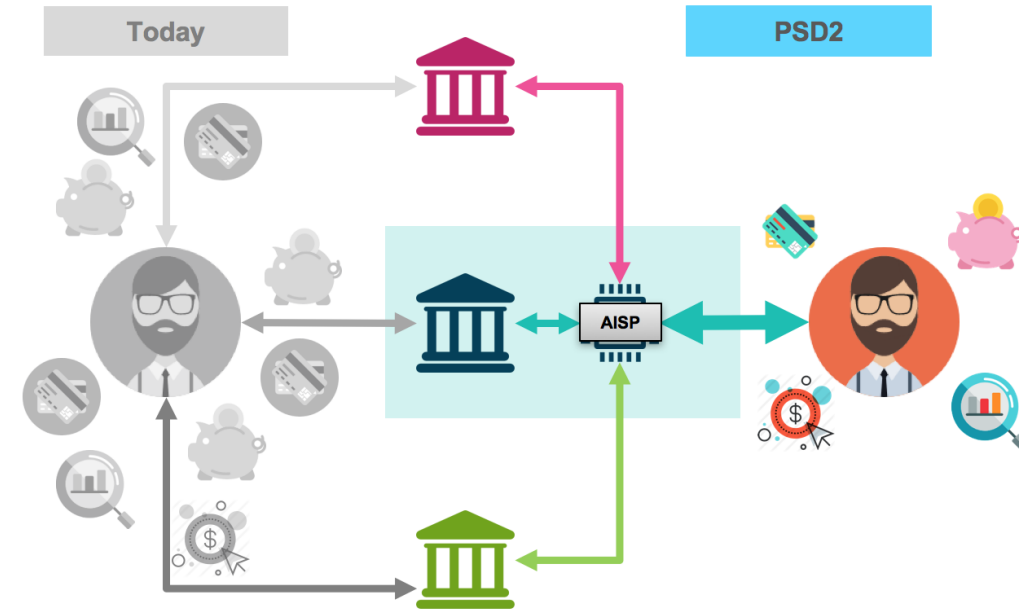
- This kind of mission inserts holes in consultant's planning so it was a Tetris © to fill them according to other's client's missions (*including this kind of mission for others client*).
- Need high flexibility to adapt to all changes on Sprint planning or content on LUXHUB side.
- Need to schedule two consultants on this mission to ensure the continuity of service/support:
 - AppSec team is currently composed of four peoples but we hire !!!
 - <https://www.excellium-services.com/application-security-consultant/>



Excellium: Challenges

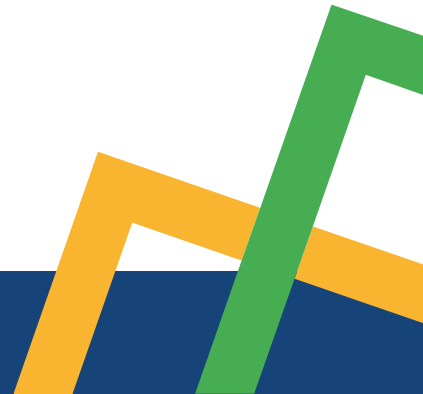
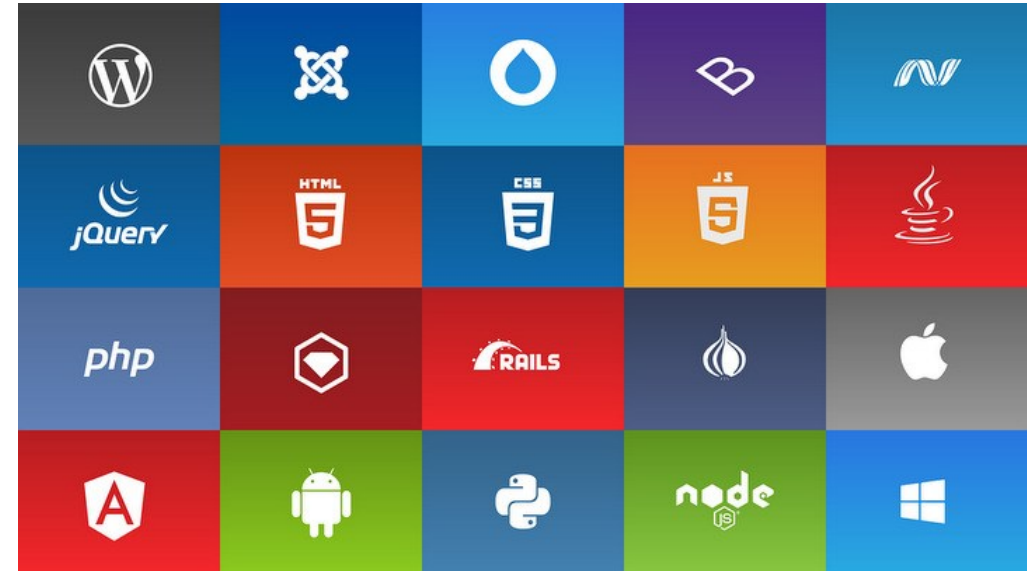
- **Human:**

- Require for the consultant to juggle with different technology/business/regulation/human contexts in a same week:
 - Brings a big mental tiredness for the involved consultants.
- Require to learn in a small timeframe the PSD2 (three different specifications) context from a regulation and technology point of view.
- Require to fully integrate the Agile mind-set/philosophy/concept for all proposals made to LUXHUB in order to not create friction in the Agile process.



Excellium: Challenges

- **Technology:**
 - Require to learn in a small timeframe the technology stack and architecture of the client (REST, OAUTH2, JWT, HTTP-SIGNATURE, PKI...).
 - Require to be able to provide hand-on advice composed of code snippet, configuration snippet, scanner configuration... No “theoretical” stuff, only directly usable elements provided to LUXHUB.

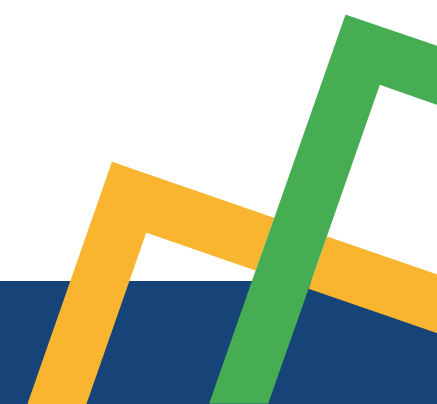


Excellium: Rewards

- No significant security issues found during the security assessment by the external company.
- Secure software delivered in time.
- Security knowledge spread to LUXHUB teams.
- Happy customer.
- Knowledge of PSD2 earned.



Respected our motto: “**Exploit Shall Not Pass**”



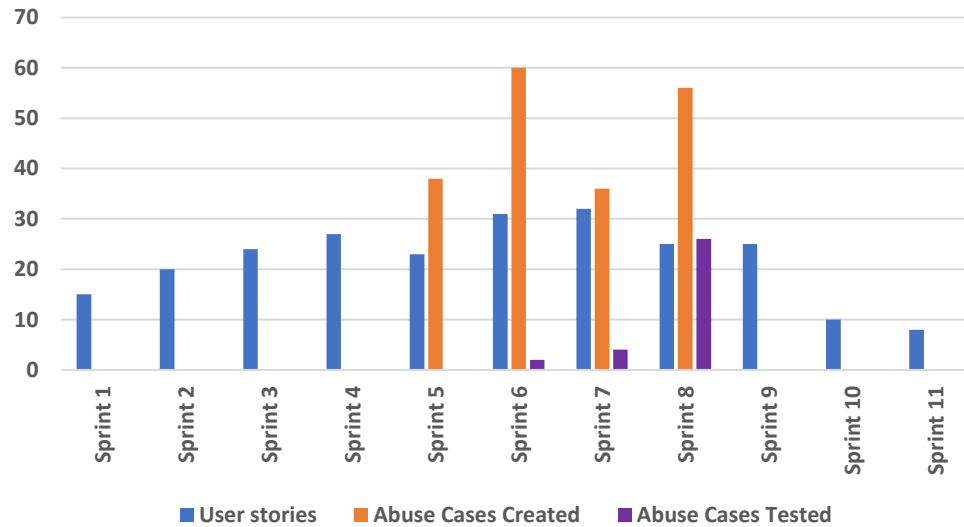
Statistics

Sprints: **11**
User Stories: **194**
Abuse Cases : **56**

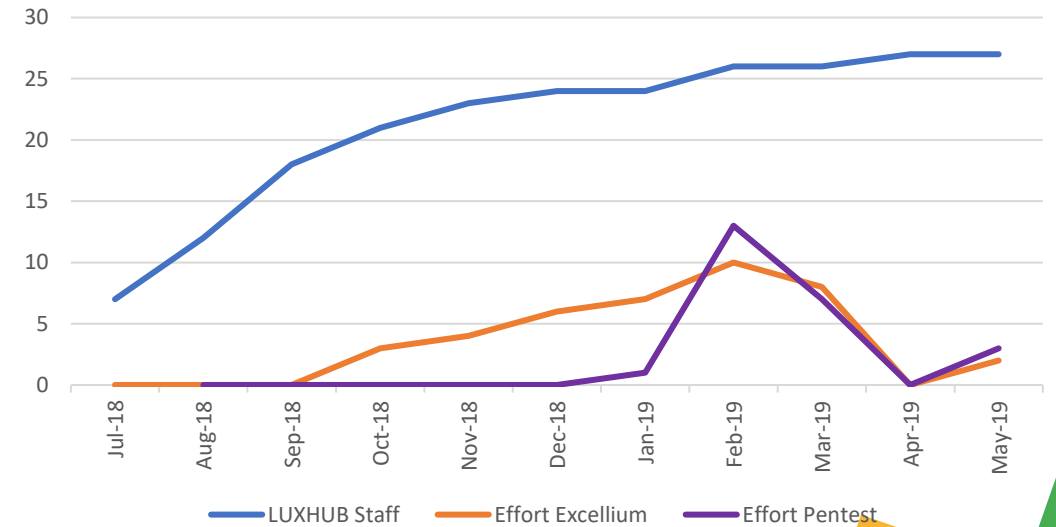
Project Effort : **5900 MD**
Effort Appsec : **40 MD**
Effort Pentest : **24 MD**

~1%

User Stories / Abuse Cases evolution



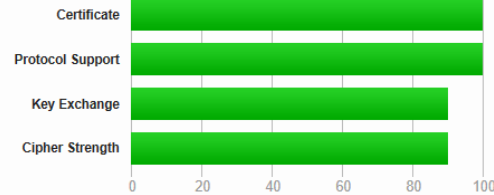
Project Staff (FTE) / Excellium Effort (MD)



Results



Overall Rating



Security Headers

Sponsored by **netsparker**



Site: <https://www.luxhub.com/>
IP Address: 213.133.106.58
Report Time: 27 May 2019 15:52:00 UTC

Headers: ✓ X-Frame-Options ✓ Referrer-Policy ✓ X-Content-Type-Options ✓ X-XSS-Protection
✓ Strict-Transport-Security ✓ Content-Security-Policy ✓ Feature-Policy

Warning: Grade capped at A, please see warnings below.

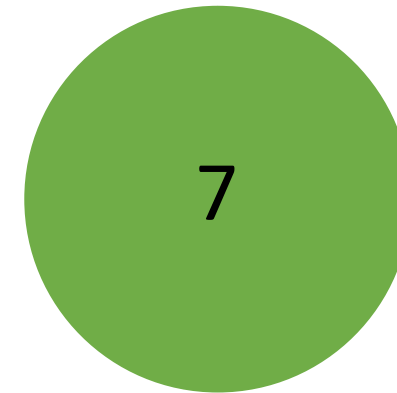
Penetration Test results

Black Box

White Box

Full scope (Portal, XS2A, Backend Infrastructure)

Penetration Test Vulnerabilities



■ LOW ■ MEDIUM ■ HIGH ■ CRITICAL

Benefits

Implication of Dev Teams

Change from “I found X vulnerabilities in your code, fix them” to “let’s find together how to build this securely”

Agile Security

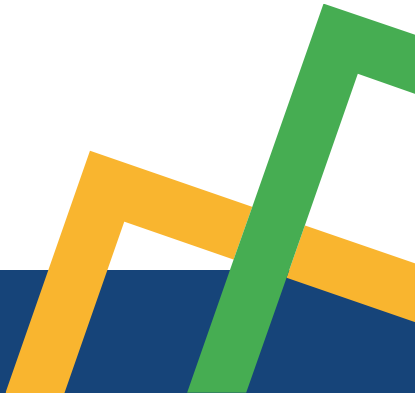
Security Acceptance Criterias in the User Story and fast response time to fix issues

Reuse Security

Existing Abuse Cases can be reused for new developments (Don’t start from scratch)

Reduce Time-to-market

Penetration test results = only LOW findings, no showstopper before Go-Live



Challenges

Implication of Dev Teams

Business requirements first, Security later

Planning

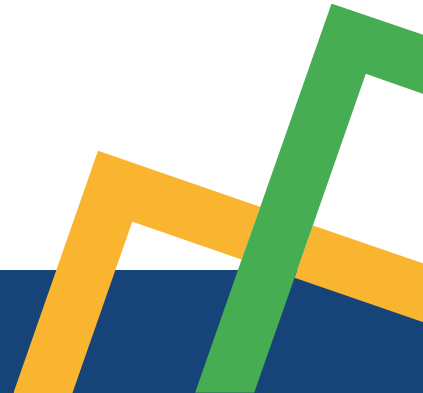
Coordinate external SP resources with Internal Staff development Team

Autonomy

Difficult and time-consuming to give an Appsec mindset to a developer

Prioritisation

Always keep in mind Business Impact and Exploitability to select Abuse Cases



Ongoing improvement

Automation

- DAST (ZAP Proxy)
- SOAP UI Test tool

Handover

- Training Dev Team
- Abuse Case identification

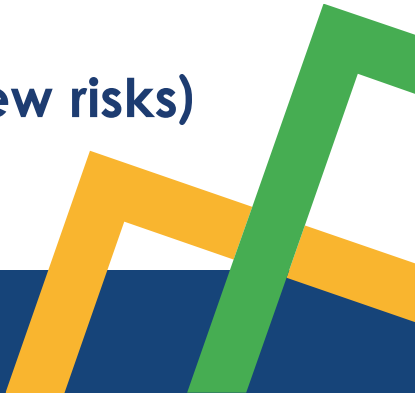
Integration (Jira)

- Tag Abuse Cases
- Link to User Stories

Documentation & Reporting

- Create Abuse Case referential
- Dashboards & KPIs

+ Follow LUXHUB Marketplace development (new API's, new actors, new risks)



FinTechs & Software Providers

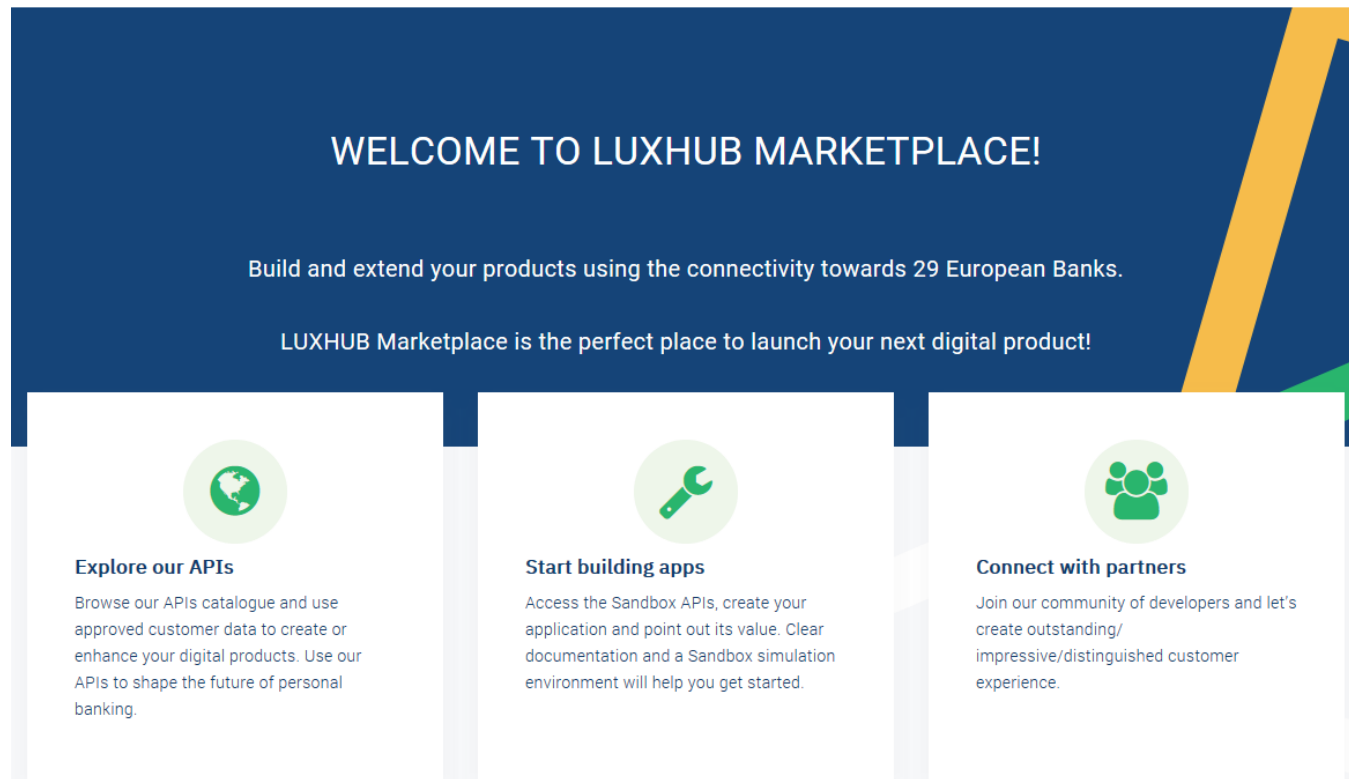
- offer their services directly to a great number of Financial Institutions.

Financial Institutions

- cooperate easily with FinTechs / Software Providers in a secure way.
- expose additional (public / private) non-PSD2 APIs to their partners/customers

Other entities (regulated or not)

- easy and secured way to connect to their potential customers.



The screenshot shows the LUXHUB Marketplace homepage. It features a dark blue header with the LUXHUB logo and navigation links. The main content area has a dark blue background with white text. Below this, there are three white boxes, each with a green icon and a title. The first box has a globe icon and is titled 'Explore our APIs'. The second box has a wrench icon and is titled 'Start building apps'. The third box has a group of people icon and is titled 'Connect with partners'.

WELCOME TO LUXHUB MARKETPLACE!

Build and extend your products using the connectivity towards 29 European Banks.

LUXHUB Marketplace is the perfect place to launch your next digital product!



Explore our APIs

Browse our APIs catalogue and use approved customer data to create or enhance your digital products. Use our APIs to shape the future of personal banking.



Start building apps

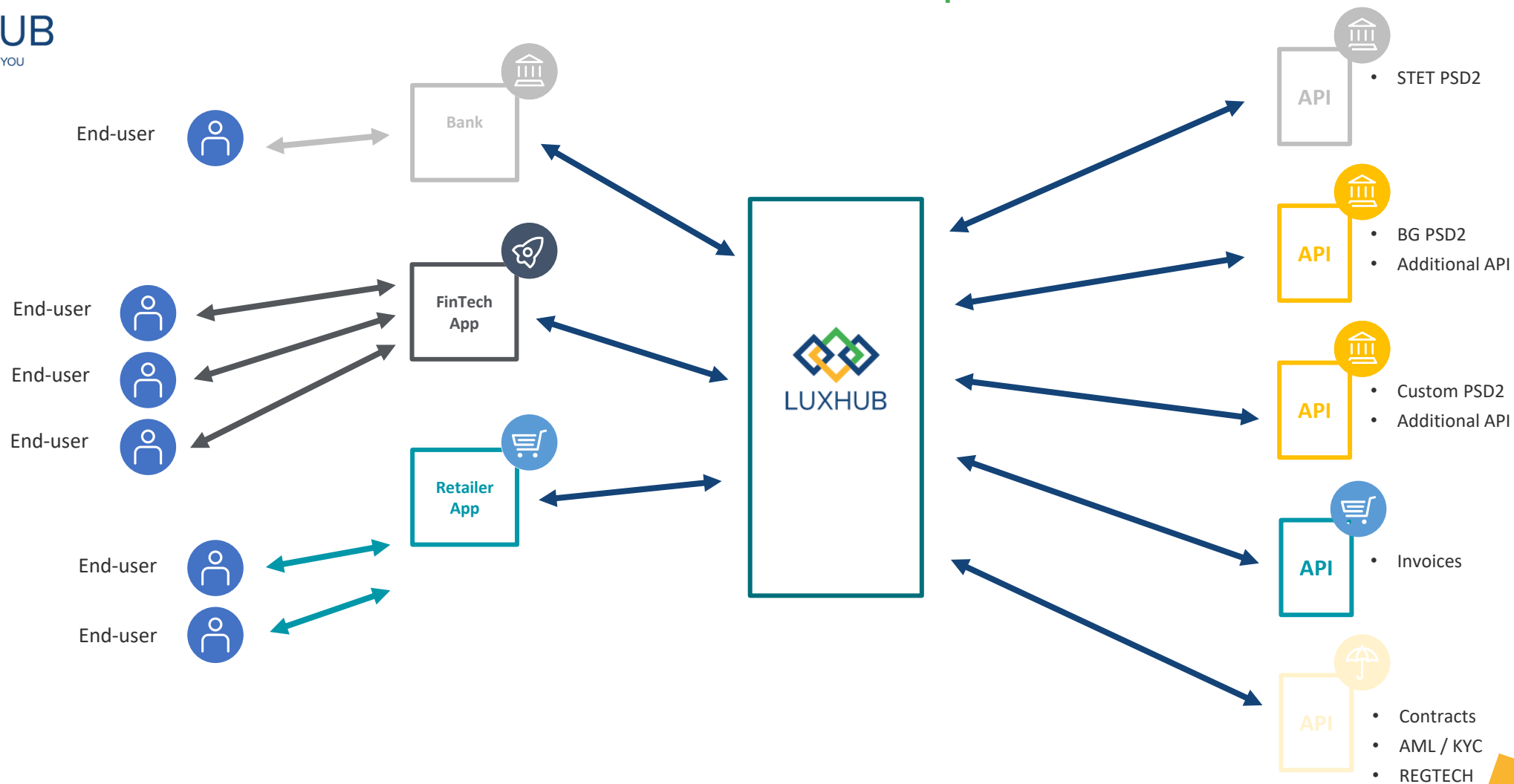
Access the Sandbox APIs, create your application and point out its value. Clear documentation and a Sandbox simulation environment will help you get started.



Connect with partners

Join our community of developers and let's create outstanding/impressive/distinguished customer experience.

LUXHUB Marketplace



Conclusion

Project Management moved from **WATERFALL** to **AGILE** methodologies

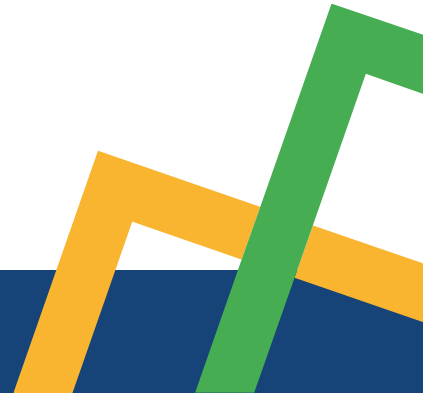
⇒ The “Security Gates” model no longer works

⇒ Adapt to **(Sec)Devops** mindset: empower people, give them security responsibilities

⇒ Build Security (and Privacy) **by Design**

⇒ Be **pragmatic** (risk-based approach)

⇒ Work with **THE BEST PARTNER**





THANK YOU !

Yannick Antoine, CISO LUXHUB
Application Security Team, Excellium

